nestself

Authentication, authorization and infrastructure strategy

How people sign in, what each of them may do, and where NestSelf runs on AWS. An overview for review; the engineering reference carries every detail.

Version 1.0
21 October 2026

Status
Draft for founder review

Engineering reference
docs/tasks/auth/auth-strategy.md

OVERVIEW

What this strategy decides

Thirteen of the thirty-six decisions carry the design. Every decision has a numbered entry, with conditions and dissent, in the engineering reference.

Cognito authenticates everyone. NestSelf decides what each person may do, in its own database, through one decision function. Web apps hold a cookie, never a token. Employees never set a password.

D-01 **One Cognito user pool per environment in Frankfurt, Essentials plan, for every population**
Email codes, passkeys and token rotation come with the plan; ten thousand direct users are free; nothing leaves the EU.

D-02 **No authorization data in tokens**
Tokens prove who signed in. Memberships and grants live in PostgreSQL and are read, cached for seconds, on every request.

D-03 **Invitation first; no self sign-up; linking of identities in NestSelf's database**
HR stays the gate. One identity per person across employers; Cognito's account-linking API is not used.

D-05 **Employees sign in with their employer's SSO or an emailed code; experts and staff with a password and an authenticator app**
No passwords for the largest population, no SMS, a second factor wherever someone manages other people's data.

D-06 **The API is the only OAuth client for the web apps and keeps sessions server-side**
Browsers hold an httpOnly cookie. Revoking access means deleting one key.

D-07 **The mobile app uses the standard native flow with tokens in the device keychain**
Unanimous over a custom handoff: proven libraries, what auditors expect, weeks saved. Short tokens and per-request checks close the gap.

D-08 **Each web app and its API share one origin behind CloudFront**
Strictest cookie scope, no cross-origin requests, one cookie per surface.

D-11 **NestSelf owns every sign-in screen, in Serbian, Hungarian and English**
Cognito's hosted pages offer neither language; they appear only as a silent hop during SSO.

D-12 **One SSO connection per employer, on verified email domains, started from NestSelf**
Three hundred connections fit one pool. DNS verification stops domain hijacking; portal-initiated sign-in stays off by default.

D-15 **Authorization is a grants model with one pure decision function**
Default deny, explainable decisions, delegation envelopes, effective-access preview. Scored far above policy engines for this model.

D-20 **Private case content is a separate domain with four doors and no administrator key**
Participant, assigned expert, supervision grant or time-limited emergency access. Platform and support roles are refused in code.

D-24 **ECS Fargate, RDS PostgreSQL, ElastiCache Valkey, S3 and CloudFront, all written as CDK**
founder: budget
Infrastructure two engineers can run. Multi-AZ database and managed NAT from the first paying client unless the founder chooses savings.

D-35 **Five phases, about fifteen weeks to an SSO-ready pilot**
Foundations and spikes, identity and sessions, authorization administration, first employer SSO, hardening. Compliance runs alongside.

PEOPLE

Who signs in, and how

Five populations, one identity each. Eligibility comes from memberships; authority comes from grants.

Population	Signs in with	Second factor	Web session	Where
Employee of a client with SSO	The employer's identity provider	The employer's own	30 min idle · 12 h · device remembered 30 days	Workspace, mobile app
Employee of a client without SSO	Emailed one-time code	Optional	30 min idle · 12 h · device remembered 30 days	Workspace, mobile app
Employer administrator owner, HR, manager, approver, finance, reporting	As an employee, then a context switch	Required authenticator app, or the IdP's	1 h idle · 8 h · step-up every 4 h	Workspace, organization context
Expert and expert lead	Password	Required authenticator app	8 h idle · 7 days	Expert workspace
NestSelf staff operations, content, coordinators, support, finance	Password; a workspace IdP later	Required authenticator app	1 h idle · 8 h · step-up every 2 h	Admin
Platform owner	Password	Required	1 h idle · 8 h · step-up every hour	Admin
Event facilitator or supplier later	Scoped delivery link	None	Per activity	Delivery packet or portal

Identity is not eligibility

A person keeps one identity for life on the platform. Employers add and end memberships with effective dates. A manager is an employee who also holds grants, and switches explicitly into the organization context to use them.

4
sign-in languages: Serbian Latin and Cyrillic, Hungarian, English

0
passwords for employees; codes by email or the employer's SSO

0
SMS at launch; email and authenticator apps instead

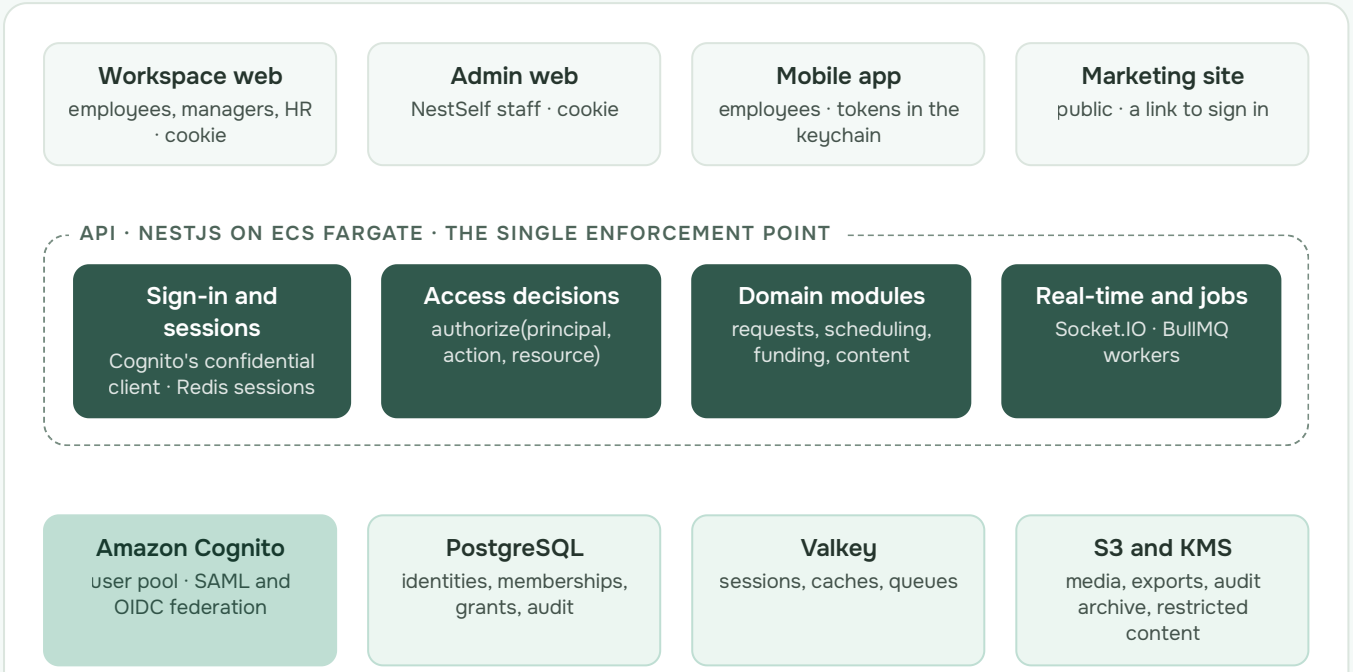
A second factor where it matters

Anyone acting on other people's data has one: experts, staff and every employer administrator. For SSO clients the employer's provider enforces it and the onboarding checklist records that. Employees reading content and booking their own sessions are not burdened with it.

ARCHITECTURE

The platform at a glance

Clients talk only to the API. Only the API talks to Cognito and the data stores.



Reading the diagram

Arrows are omitted on purpose. Every client request lands in the API, which authenticates the caller, resolves who they are from the database, and asks the decision function before touching any record.

Five places where the same decision is enforced	What happens
HTTP routes	Every route declares the action it needs or is public; a test fails the build otherwise.
Background jobs	Carry the principal and re-check the decision when they run.
Exports	Authorized first, cohort rules applied, then streamed.
Files	Short-lived signed links, issued only after a decision.
Real-time channels	Authenticated handshake, re-checked per subscription, dropped when access changes.

Client	What it holds	How it reaches the API
Workspace and admin	One httpOnly cookie naming a server-side session	Same origin, /api/* through CloudFront
Mobile app	Cognito tokens in secure storage, 15-minute access tokens	Bearer token to api.nestself.rs
Marketing site	Nothing	Links to the workspace sign-in page

SIGN-IN JOURNEYS

How employees sign in

Identifier-first: the email decides the route. The browser never receives a token, only a cookie that names a server-side session.

An employee of a client with single sign-on

EMPLOYEE	Opens the workspace and types a work email on the NestSelf sign-in page, in their own language.
API	**Finds a verified email domain with an active SSO connection, starts the authorization-code flow as Cognito's confidential client and redirects the browser straight to that identity provider.**
EMPLOYER IDP	Authenticates the employee with the employer's own second factor and returns a signed assertion to Cognito. No Cognito screen is shown.
COGNITO	Issues an authorization code to the API's callback address.
API	**Exchanges the code, verifies the tokens, binds the identity to the pending invitation, creates the session and sets the httpOnly cookie.**
EMPLOYEE	Lands in the personal workspace. A manager also sees the switch to the organization context.

An employee of a client without an identity provider

EMPLOYEE	Types a work or personal email address. No SSO connection matches the domain.
API	**Shows the same next step whether or not the address is known, so nothing reveals who has an account, and asks Cognito to send a one-time code using NestSelf's localised email template.**
EMPLOYEE	Enters the code from the email. On the first visit the invitation link already carried the token that binds this identity to the membership.
API	**Completes the Cognito challenge, creates the session, sets the cookie and records the sign-in method and time on the session for later step-up checks.**
EMPLOYEE	Lands in the workspace. A "remember this device" choice keeps the personal workspace signed in on that device; the organization context always asks again.

No passwords for employees

Email codes and employer SSO cover every employee. Nothing to forget, nothing to leak, nothing to migrate.

One page, four languages

Serbian Latin and Cyrillic, Hungarian and English. Cognito's pages offer none of the first three, so NestSelf owns every screen.

Neutral by design

Invitation and code emails never name a service category. Only the signed-in workspace shows what is available.

SIGN-IN JOURNEYS

Experts, staff and the mobile app

Higher trust means a password and an authenticator app. The phone follows the standard native flow.

An expert on the web

EXPERT	Types their email; the API answers that this identity signs in with a password.
API	Checks the password with Cognito on the server, receives a one-time-code challenge for the authenticator app and relays it. The browser never talks to Cognito.
EXPERT	Enters the six-digit code from the authenticator app enrolled at activation.
API	Completes the challenge, creates the session with its method and time recorded, sets the cookie. Staff sign in the same way in the admin app, with shorter sessions.

An employee of an SSO client on the phone

EMPLOYEE	Types the work email in the app; the app learns that this domain uses the employer's identity provider.
APP	Opens the system browser to Cognito with a one-time code challenge, naming the employer's provider. No screen is shown before the employer's own sign-in page.
EMPLOYER IDP	Authenticates the employee and returns to Cognito, which returns an authorization code to the app's registered link.
APP	Exchanges the code with Cognito, stores the tokens in the device keychain and calls the API with a short-lived bearer token. Employees without SSO receive their emailed code inside the app instead.
API	Verifies the token's signature, resolves the person from the database, checks that the membership is still active and that the token family is not revoked, then decides.

What the browser never sees

Cognito tokens. The web apps hold one cookie that names a session in Valkey; signing out deletes it.

What the phone holds

Rotating Cognito tokens in secure storage, 15-minute access tokens, biometric gate for sensitive reads, discarded after 30 days unused.

How access ends

Ending a membership deletes sessions, revokes refresh tokens, disconnects live channels and denylists the phone's token family, within a second.

ENTERPRISE SSO

Connecting an employer's identity provider

One connection per employer, registered by NestSelf operations. Employees never see a Cognito screen.

Two weeks, mostly waiting

The work on NestSelf's side is a few hours. The elapsed time is the client's IT queue: a DNS record, an identity-provider application and a test user.

NestSelf sends

- Service-provider entity ID and the assertion consumer URL
- Signing certificate
- The attribute list: persistent NameID, email, given name, family name
- A DNS verification token per email domain

The client sends

- Metadata URL or XML (SAML) or issuer and client ID (OIDC)
- The list of email domains employees use
- A test account
- Whether sign-in may start from their portal (off by default)

1. **Register the connection**
   Operations create the connection in draft state: protocol, provider name, the organization it belongs to. Nothing routes to it yet.
2. **Verify the email domains**
   The client publishes a DNS record with the token. Only verified domains take part in routing; public mail domains are refused.
3. **Exchange metadata and map attributes**
   The provider is created in Cognito from the metadata. The persistent NameID identifies the person; email and names fill the profile. IdP groups are ignored: access comes from NestSelf grants.
4. **Test with one user**
   The connection moves to testing. A test sign-in must produce a verified email, bind to an invitation and show the right names before anyone else is routed.
5. **Invite the roster**
   HR imports the roster; each person receives a neutral invitation. If the client prefers, verified-domain sign-ins may create memberships automatically into a default unit.
6. **Go live and watch the certificate**
   The connection becomes active. Cognito refreshes metadata within six hours; a reminder fires 30 days before the IdP certificate expires so rotation overlaps.

Identity provider	NameID	Notes
Microsoft Entra ID	user.objectid	Rename claims to short names; scope group claims to the app or leave them out
Google Workspace	Primary email or a custom attribute	Use a SAML app, not Google social sign-in
Okta	Persistent, not email	Standard SAML 2.0 app; SHA-256 signing

> **Sign-in starts at NestSelf, not at a portal**
> Employees type their work email on the NestSelf sign-in page and are sent to their company's identity provider, whose second factor applies. Portal-initiated sign-in stays off unless the client accepts the replay risk in writing.

LIFECYCLE

Identity stays, eligibility changes

A person keeps one identity for life. Employers grant and withdraw eligibility with effective dates.

Every event below changes memberships, grants or sessions in a predictable way, and each writes an audit event. Leaving an employer ends access from a date; it never deletes the person, their professional records or the settlement history.

< 1 s

from an HR deactivation to every session, websocket and delegation of that membership being closed

Event	What changes	Sessions	Grants
HR invites	An invitation with an expiry and a revocable token; duplicates against the roster are reported before the batch applies.	None exist yet	None until activation
Employee activates	The invitation binds the person's identity to a membership that starts today. A returning person reuses their identity.	First session created	Employee template applied
Second organization	A new membership with its own dates and unit. Nothing from the first organization is visible in the second.	Unchanged; a context picker appears	Independent per organization
Team move	The membership's unit changes from an effective date; history keeps the old attribution.	Unchanged	Re-evaluated at the date; unit-scoped grants end
Becomes a manager	Grants, not a role flag: activity requests, budget reading, approval up to a ceiling for an explicit unit.	Organization context becomes available	Created from the manager template, then adjusted
Delegates while away	A time-limited grant inside the delegator's own envelope; self-approval conflicts route to the alternate.	Unchanged	Expires on its own
Leaves the employer	The membership ends on a date. Appointments follow the continuity rule the contract defines. Records stay.	Closed for that organization	All grants of that organization end
Suspended	A platform or HR action for a security or policy reason.	All closed at once	Frozen, not deleted
Expert credential expires	Matching stops for the affected categories; assigned cases follow continuity.	Unchanged	Category actions suspended

Nightly reconciliation

A job compares memberships, grants and open sessions and closes what the event path missed.

Effective dates everywhere

Memberships, grants, authorities and credentials carry start and end dates, read at the moment of each request.

HR actions never delete

Deactivation and deletion are different requests; deletion follows the retention policy of each data domain.

AUTHORIZATION

Anatomy of a grant

Grants replace hard-coded roles. Templates make onboarding understandable; grants are what the platform enforces.

Grant	grt_7f3c · created 2026-12-15
Subject	A team manager in the Engineering department of one employer
Actions	`events.request` `budget.read` `spend.approve`
Scope	Org unit Engineering, including its sub-teams; never another department or company
Conditions	Up to EUR 500 per approval; categories: workshops, team activities
Validity	2027-01-01 to 2027-12-31
Delegation envelope	May delegate approval up to EUR 500 inside Engineering for at most 30 days
Granted by	The employer owner, from the team manager template, adjusted
Audit	Creation, adjustments, every consequential use, revocation

Scope type	Covers	Typical holder
Platform	Every organization	Platform owner, NestSelf finance
Organization	One employer, all units	Employer owner, HR administrator
Org unit	One unit; descendants only if included	Team manager, reporting user
Assigned	Named clients, queues, cases, collections	Operations, coordinators, experts, authors
Own	The person's own records	Employee

1. **Choose a template**
   Seventeen templates mirror the responsibilities in the product specification, from platform owner to event supplier.
2. **Set the scope**
   The whole organization, one unit with or without its descendants, assigned clients, queues or cases, or only the person's own records.
3. **Adjust conditions and validity**
   Ceilings, categories, a confidential-approver flag, start and end dates. Nothing may exceed what the grantor holds.
4. **Preview, then apply**
   The effective-access preview shows exactly which actions on which scopes the person will have before the grant exists.

Operations workspace

7 templates

Platform owner, client operations, content author, content publisher, service coordinator, support operator, NestSelf finance.

Organization workspace

6 templates

Employer owner, HR administrator, team manager, approver, employer finance, reporting user.

Expert workspace

2 templates

Expert, expert lead. Clinical supervision is a separate, explicit grant.

Employee workspace

1 template, 1 later

Employee; event supplier through a scoped delivery packet later.

A manager relationship is not a grant

Being someone's line manager grants nothing by itself: no reports, no spending, no descendant units. Access always comes from an explicit grant with a scope.

AUTHORIZATION

Who sees what

The visibility rules of the product specification, as the platform enforces them. The same rule applies to screens, search, exports, notifications and logs.

Own the person's own records

Assigned only through an explicit assignment

Scoped within an explicit grant scope

Aggregate privacy-safe totals above the cohort threshold

Unavailable no path exists, including for administrators

Information	Employee	Assigned expert	NestSelf operations	Employer and managers
Membership, eligibility and team	Own	Assigned minimum needed for delivery	Scoped assigned clients' people operations	Scoped roster administrators in their units
Private intake and professional conversation	Own	Assigned the assigned case only	Unavailable except an explicitly authorized intake function	Unavailable
Professional notes, if stored	Defined patient-facing route	Assigned responsible professional; supervision by explicit grant	Unavailable separate controls; emergency access only	Unavailable
Appointment logistics	Own	Own assignments	Scoped assigned scheduling queues	Unavailable no named consultation roster
Payer authorization and billing reference	Own coverage summary	Minimum coverage fields	Scoped designated finance staff	Scoped the employer's permitted financial view
Consultation usage and costs	Own	Own delivery and payment records	Scoped operational and financial scope	Aggregate a disclosed funding exception only when the employee chose it
Team event invitations and logistics	Own invited activities	Assigned facilitation	Scoped coordinators	Scoped the organizer of that event
Content consumption and feedback	Own	Only if intentionally shared	Aggregate restricted follow-up access	Aggregate with suppression; no named reading history

The cohort threshold

Employer reports show a cell only when at least ten people are in it, suppress complementary totals and use monthly windows. The exact number is a product and privacy decision; ten is the default this strategy assumes.

Administrators are not an exception

A platform owner or a support operator reaches the confidential domain only through an approved, time-limited emergency access with a written purpose. Routine support sees redacted diagnostics.

AUTHORIZATION

One decision function, everywhere

authorize(principal, action, resource) is pure once its inputs are loaded, explains itself, and is the only path to a yes.

1. **Is the person active?**
   Suspended or deactivated users are refused before anything else is read.
2. **Is the context valid?**
   The organization context needs an active membership; expert and operations contexts need the matching capability.
3. **Is this restricted content?**
   If so, only a participant, an assignment, a supervision grant or emergency access can allow it. Administrative grants are refused here, in code.
4. **Which grants match?**
   Action and scope, with the organization tree resolved from the closure table; assignments cover queues, cases and clients.
5. **Do the conditions hold?**
   Spending ceiling and currency, permitted categories, confidential approver, time window, validity dates.
6. **Is anyone approving themselves?**
   Denied unless the organization documented otherwise; the router always finds an alternate.
7. **Explain the answer**
   Allowed or denied, the grant ids that mattered, a reason, and a trace used by tests and the effective-access preview.

```
authorize(principal, 'spend.approve', {
  kind: 'approval', orgId, orgUnitId,
  amountMinor: 42000, currency: 'EUR',
requesterId,
})
// allowed: true · grantIds: ['grt_7f3c']
// explanation: org_unit scope incl.
descendants;
//              ceiling 50000 EUR holds
```

Four doors into private case content

The participant
The employee reads their own intake and conversations.

The assigned expert
Only while the assignment is active; nothing from other cases.

Clinical supervision
An explicit, separate grant; operational leadership does not imply it.

Emergency access
Written purpose, one case or one person, approved by another platform owner, four hours at most, read-only, every read audited, an alarm on activation.

Platform owner, operations, support, employer
No path. Support sees redacted diagnostics: connection state, delivery status, never content.

Separate on every layer

Restricted data has its own module, database models, S3 bucket and encryption key. Management screens and personal screens are served by different controllers, so a mistake in one cannot leak the other.

SESSIONS

Sessions and security posture

Short tokens, short sessions for privileged work, re-authentication before consequential actions.

Population and context	Idle	Absolute	Remember device	Mobile	Step-up interval
Employee, personal context	30 min	12 h	30 days	30 days idle · 90 days	per action
Employee acting in the organization context	1 h	8 h	no	not at pilot	4 h
Employer owner, HR, finance	1 h	8 h	no	not at pilot	4 h
Expert	8 h	7 days	no	later	per action
Staff	1 h	8 h	no	none	2 h
Platform owner	1 h	8 h	no	none	1 h

Before this action	Sign in again if older than
Requesting or approving emergency access	5 minutes
First restricted content read in a session	15 minutes
Exports and reports leaving the platform	15 minutes
Financial operations above the client's threshold	15 minutes
Grant, approval-authority or SSO changes; deactivating people	30 minutes

15
minutes: Cognito access tokens, refreshed server-side for the web

30
seconds: the single-use ticket that opens a real-time channel

10
seconds of grace on rotating refresh tokens; reuse is detected

What the posture rests on

No passwords in flight from browsers to Cognito; rate limits and a web application firewall on sign-in; prevent-user-existence errors; invitation-only accounts; audit of every sign-in, decision change and restricted read; nightly reconciliation of sessions against memberships.

Revocation paths

Sign out, sign out everywhere, membership end, suspension, staff leaver. Web sessions end at once; mobile within one access-token lifetime at most, usually at once through the denylist.

Federated step-up

A fresh round trip to the employer's provider when it honours a forced re-login; an emailed code from NestSelf when it does not.

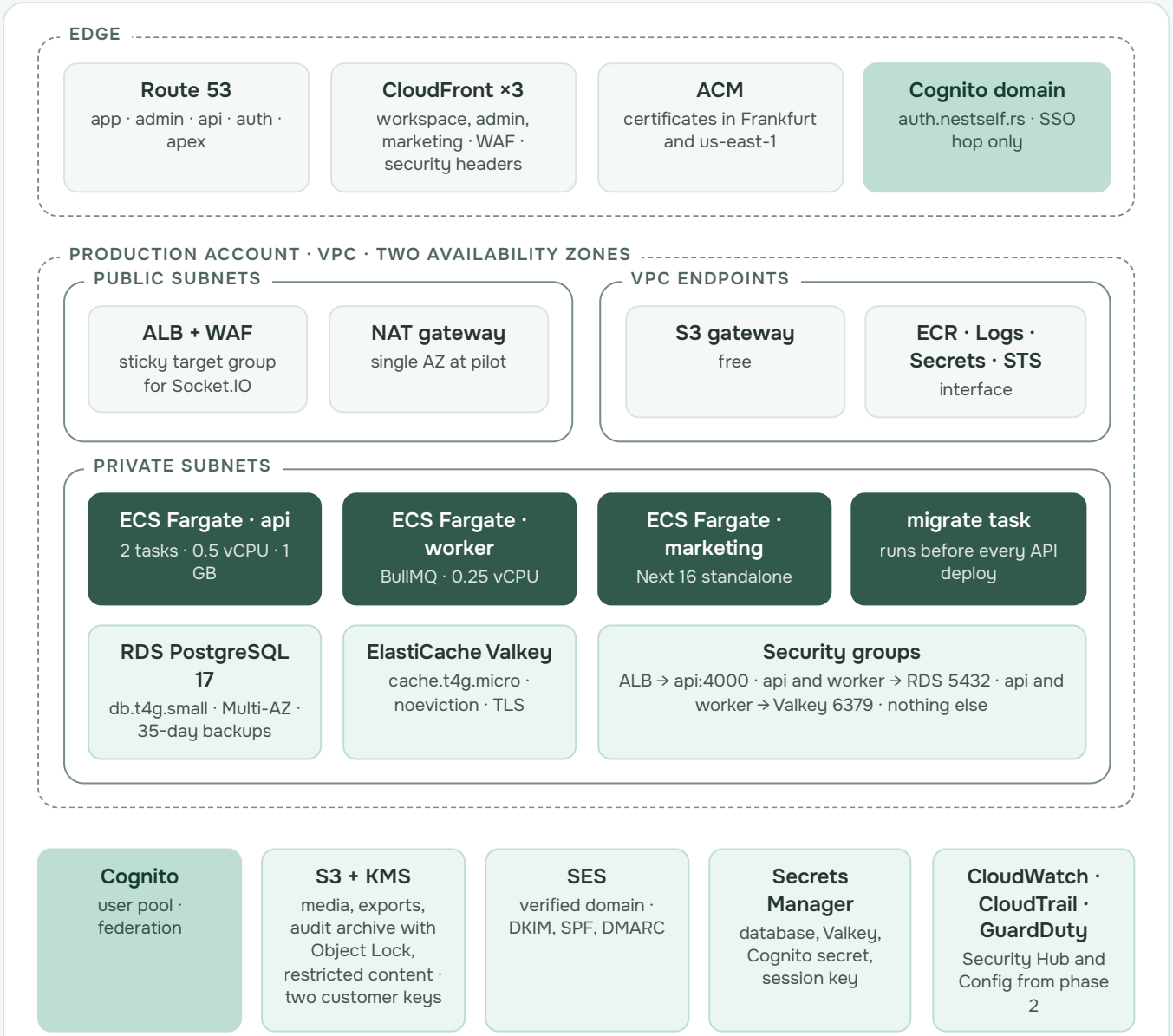
Later

Passkeys as a phishing-resistant factor, Cognito's threat protection plan if a test or a client requires it, and Cognito's own step-up claims once generally available.

AWS

The AWS map

Everything in eu-central-1, Frankfurt. Backups copy to Ireland. Nothing elsewhere.



Accounts and environments

Development runs locally on Docker Compose. Staging and production are separate AWS accounts under one organization, with single sign-on for the console and region-restricting policies from phase 2.

Residency

Pool, database, cache, storage, email and keys in Frankfurt. Cross-region copies go only to Ireland. Cognito analytics to the US stays off.

Written as code

Nine CDK stacks in TypeScript inside the monorepo, checked by cdk-nag in CI, deployed by GitHub Actions with short-lived OIDC credentials.

AWS

Delivery and operations

One pipeline, two environments, no long-lived credentials anywhere.

A release, step by step

Pushing to main deploys staging. A release tag deploys production after a manual approval. Both run the same steps.

1 h · 4 h
recovery point and recovery time objectives for the pilot

30 days
application log retention in production; audit events kept for years in the archive

1. **Check**
   Lint, typecheck, unit and property tests, the golden decision table, the default-deny route test, CDK synth with cdk-nag.
2. **Build**
   Container images for the API, worker and marketing site tagged by commit; pushed to ECR and scanned, critical findings block the release.
3. **Migrate**
   A one-off ECS task runs the Prisma migrations against the target database and the pipeline waits for its exit code.
4. **Deploy**
   New task definitions roll out behind the load balancer with the deployment circuit breaker; SPA bundles sync to S3 and CloudFront invalidates.
5. **Verify**
   Health checks confirm database and cache; a smoke sign-in runs against staging; alarms watch errors and latency after the switch.

Environment	Where	Identity	Data
Development	Docker Compose on the laptop	Sample sessions and the role switcher, or a staging pool	Fixtures from the sample-data package
Staging	AWS account nestself-staging	Its own Cognito pool and test SSO connection	Aurora Serverless that pauses when idle; synthetic data only
Production	AWS account nestself-production	Its own pool, real connections	RDS Multi-AZ, encrypted, backed up to Ireland

Observed

Structured logs with redaction; alarms on errors, latency, saturation, failed sign-ins and every emergency access activation.

Rehearsed

A quarterly restore drill after the first paying client; a tabletop breach exercise before the pilot.

Rotated

Database credentials every 30 days; the Cognito client secret and session key yearly with dual acceptance; keys automatically.

COMPLIANCE

Compliance posture

Engineering background for the legal work, not legal advice. Counsel in Serbia and Hungary must confirm the items marked.

Processing purpose	Controller	NestSelf's role
Platform identity and sign-in	NestSelf	Controller; contract with the user
Employer wellbeing programme	The employer	Processor under a data processing agreement
Professional and clinical content	NestSelf	Controller; explicit consent or health-professional basis counsel
Expert management	NestSelf	Controller
Aggregate employer reporting	The employer	Processor; cohort rules apply

Data flow	Mechanism if NestSelf is a Serbian company
Hungarian employer to NestSelf	EU standard contractual clauses, module two, inside the agreement
Serbian employer to NestSelf	Domestic processing agreement
NestSelf to AWS Frankfurt	Germany is an adequate destination under Serbian law; the AWS data processing addendum covers the EU side
Staff in Serbia reading Hungarian data	Covered by the same clauses plus access controls

Two questions decide the rest

Where NestSelf is incorporated, and whether its counselling counts as healthcare activity. The first sets the contract template and supervisory authority; the second sets retention for conversations (five years, or fifteen in Serbia and thirty in Hungary) and whether health-record reporting duties apply.

Before the first real employee signs in

- [ ] Data protection impact assessment completed and signed
- [ ] Data protection officer appointed or the function designated
- [ ] Processing agreement template with the right clauses
- [ ] Privacy notices in Serbian, Hungarian and English
- [ ] Breach procedure: clients within 24 hours, authorities within 72
- [ ] Data subject rights workflow: access, export, erasure with retention checks
- [ ] Audit logging of sign-ins, decisions, access to restricted data, exports
- [ ] Second factor enforced for staff, experts and employer administrators
- [ ] Encryption in transit and at rest with customer-managed keys
- [ ] Cohort threshold enforced in every employer report
- [ ] Cognito, email and storage pinned to Frankfurt; analytics routing to the US disabled
- [ ] Professional notes kept out of the platform until the storage decision is made
- [ ] Record of processing and sub-processor register maintained

5 y
default retention for conversation content, configurable per service and jurisdiction

20 y
financial ledger and insurer authorization records, Serbian accounting law

COST

Pilot cost snapshot

Monthly, in US dollars, before taxes. Frankfurt prices come from secondary sources and must be confirmed in the AWS Pricing Calculator.

Component	Pilot	20,000 MAU
Cognito, Essentials plan	0	45 to 300
ECS Fargate: API, worker, marketing	41 to 60	200 to 350
RDS PostgreSQL, Multi-AZ	59	150 to 250
ElastiCache Valkey	9 to 13	40 to 80
Application load balancer	27	40 to 60
NAT gateway, single zone	33 plus data	70 plus data
CloudFront, WAF, Route 53, certificates	20 to 40	80 to 150
S3, KMS, Secrets Manager, logs	10 to 20	60 to 120
SES, Expo push	under 5	10 to 30
Expo application services (mobile builds)	19	19 to 99
Video (Chime SDK), 500 half-hour sessions	51	by volume
Total, approximate	**235 to 280**	**800 to 1,000**

Cognito scenarios: five hundred direct and fifty federated users cost nothing; two thousand direct and three thousand federated about $44; one thousand direct and nine thousand federated about $134. At two hundred thousand users Cognito becomes the largest line and the identity-provider abstraction keeps a migration possible.

$0

Cognito at pilot: ten thousand direct users and fifty federated users are free every month

~$250

a production-grade pilot, before the founder's budget choices

Where the pilot could save about $90 a month

Single-zone database instead of Multi-AZ ($28), a community NAT instance instead of the managed gateway ($30), free mobile build tier ($19), metered CloudFront without the flat plan. Each trades availability or operator time for money; the strategy assumes production grade from the first paying client.

What is deliberately not bought

Cognito's threat-protection plan ($0.020 per user, no free tier) until a test or a client requires it; an SSO broker ($125 per connection) until fifteen connections; SMS routes in Serbia and Hungary; a second NAT zone; RDS Proxy; ISR hosting for the marketing site.

People cost dominates

Two engineers with AI agents for about fifteen weeks to an SSO-ready pilot, plus a data protection assessment and an external data protection officer. Infrastructure is a rounding error next to that.

ROADMAP

Five phases to a pilot

About fifteen weeks to an SSO-ready pilot. Each phase ends with a test that proves the next one can start.

PHASE 0 · 2 WEEKS

Foundations and spikes

- Schema for identities, organizations, grants and audit
- The decision function with unit, property and golden-table tests
- CDK skeleton, accounts, keys, domains
- Four spikes decided in week one

Exit: golden table green in CI; spikes answered.

PHASE 1 · 6 WEEKS

Identity and sessions

- Cognito pool and clients
- Server-side sessions and cookies
- Sign-in screens in four languages, web and mobile
- Invitations, emailed codes, authenticator apps
- Staging live; pipeline; logs and alarms

Exit: an invited employee signs in on web and phone; a deactivated one is out within seconds.

PHASE 2 · 4 WEEKS

Authorization administration

- Templates, grants, delegation, preview
- Approval authorities
- Restricted-content module and emergency access
- Step-up re-authentication
- Production account, guardrails, cdk-nag

Exit: no employer or administrator view reveals private content, proven by tests.

PHASE 3 · 3 WEEKS

First employer SSO

- One SAML or OIDC connection end to end
- Domain verification and routing
- Onboarding runbook run with the client
- Replay protection, provider abstraction

Exit: an invited employee activates through the IdP; an uninvited colleague is refused.

PHASE 4 · ONGOING

Hardening and scale

- Passkeys
- Threat-protection plan if triggered
- Directory sync (SCIM)
- Access reviews, restore drills, penetration test
- Identity merge runbook; hosting re-evaluation

Trigger-driven rather than scheduled.

Four spikes decide the plan in week one

Emailed codes outside Cognito's hosted page; the session service on NestJS 12; Socket.IO through CloudFront with sticky load balancing; Prisma 7 query scoping. Each has a written fallback that costs days, not weeks.

Alongside, from week one

Data protection impact assessment, data protection officer, processing agreement template, privacy notices, breach procedure, retention schedule. None of it waits for the code.

DECISIONS FOR THE FOUNDER

What needs you

The document assumes the default in each card until you decide otherwise. None of them changes the architecture.

F-01 · Where NestSelf is incorporated

Sets the contract template, the supervisory authority and whether EU standard clauses sit in Hungarian client agreements.

Default: Serbian company; EU clauses, module two, for Hungarian clients.

F-02 · Professional notes on the platform

Clinical notes would pull in health-documentation law in both countries, with 15- and 30-year retention.

Default: not at pilot; scheduling metadata only. The restricted domain is built either way.

F-03 · Minimum reporting cohort

Below this size an employer report shows nothing. Smaller numbers raise re-identification risk.

Default: ten people per cell, confirmed with the data protection officer.

F-04 · English-only sign-in for a pilot client

Would save one to two weeks by using Cognito's hosted page, which has neither language.

Default: no; localised sign-in from day one.

F-05 · Pilot budget posture

Multi-AZ database and managed NAT, or single-zone and community NAT for about $90 a month less.

Default: production grade from the first paying client.

F-06 · Mobile token model

The panel was unanimous for the standard native flow; the custom variant is documented as rejected.

Default: standard native flow with tokens in the device keychain.

F-07 · Domain names

Placeholders are used for the site, the apps, the API and the sign-in domain.

Default: nestself.rs with app, admin, api and auth subdomains; registered in phase 0.

F-08 and F-09 · Staff identity provider; telling employees about emergency access

Staff could later sign in through a company workspace provider. Employees could be told, after the fact, when emergency access touched their records.

Defaults: Cognito with authenticator apps at pilot; yes, unless counsel objects.

Where the detail lives

docs/tasks/auth/auth-strategy.md: decisions with conditions, data model, API, infrastructure, runbooks, traceability to every story.

Eight questions for counsel

Lawful bases, healthcare classification in both countries, transfer mechanism, officer, assessment scope, cohort sign-off, SMS rules.

How a decision changes

A new revision of the decision record with the reason and the sections it touches. Never a silent edit.

Next step

Confirm or change the defaults above; phase 0 starts with the four spikes and the schema.